

Enterprise Data Processing Agreement (DPA)

Standard Contractual Clauses under GDPR Article 28 and CCPA / CPRA

1. Parties & Purpose of Processing

This Data Processing Agreement ('DPA') supplements the Master Services Agreement ('MSA') between ComplyAI Corp ('Data Controller') and the contracted Vendor ('Data Processor'). This agreement governs the processing of personal data, employee records, and business confidential intelligence in compliance with EU General Data Protection Regulation (GDPR) Regulation (EU) 2016/679 and California Consumer Privacy Act (CCPA).

2. Vendor Security Commitments & Certifications

The Vendor certifies and warrants that it maintains technical and organizational measures (TOMs) appropriate to the risk of personal data processing, including:

- Annual delivery of an unredacted SOC-2 Type II audit report conducted by an accredited CPA firm.
- ISO/IEC 27001:2022 certified Information Security Management System (ISMS).
- Annual third-party penetration testing reports with all High and Critical findings remediated within 30 days.

3. Subprocessor Appointment & Notification Clause

The Vendor shall not engage any new third-party subprocessor without adhering to the following contractual conditions:

1. **Advance Notification Window:** The Vendor must provide at least 30 business days prior written notice to ComplyAI (via privacy@complyai.internal) before onboarding any new subprocessor or modifying data flows.
2. **Right of Objection:** ComplyAI maintains the sole and uninhibited legal right to object to any proposed subprocessor on reasonable data protection or compliance grounds within 14 calendar days of receiving notice.
3. **Remedy & Termination:** If the Vendor cannot resolve ComplyAI's objection within 30 calendar days, ComplyAI may terminate the underlying Master Services Agreement immediately without financial penalty or termination fee.
4. **Subprocessor Liability:** The Vendor remains 100% fully liable to ComplyAI for the performance of its subprocessors.

4. Cross-Border Data Transfers

Any transfer of European Economic Area (EEA) personal data outside the European Union shall rely strictly upon the European Commission Standard Contractual Clauses (SCCs Module 2 - Controller to Processor) or the EU-U.S. Data Privacy Framework certification.

5. Security Breach Notification SLA

In the event of any confirmed or reasonably suspected Security Incident involving ComplyAI Customer Data:

- Immediate 24-Hour Notice: Vendor must notify ComplyAI in writing within 24 hours of first becoming aware of the breach.
- Forensic Details: Notice must contain the categories of records impacted, estimated number of data subjects, name of the Data Protection Officer leading response, and immediate mitigation actions taken.
- Root Cause Post-Mortem: Vendor must deliver a complete forensic investigation report within 72 hours of incident containment.

6. Limitation of Liability & Regulatory Indemnification

- Standard Commercial Breaches: Capped at 1x the total fees paid by ComplyAI in the preceding 12 months.
- Data Protection & Confidentiality Violations: Notwithstanding any limitation in the MSA, liability for data breaches, confidentiality failures, or willful GDPR violations shall be capped at 3x annual contract value or \$5,000,000, whichever is greater.
- Regulatory Fines: Vendor agrees to indemnify ComplyAI against any administrative fines levied by European Data Protection Authorities resulting directly from Vendor's breach of this DPA.